技术安全与恢复补充规格

受控项	内容
编号	CF-TQ-SPEC-01
版本与日期	1.1 / 2026-11-02
实现基线	v0.6.4 / 236a3933ecef；本轮未改游戏实现
审查性质	AI 领域审查；不代表真人专家签名或任何企业认证
状态	文档整改已执行；产品批准、工程待办、用户验收另行记录

1 信任边界与安全控制

边界	威胁	当前机制	准入/改进要求
浏览器→HTTP 服务	伪造座位/改 action/旧 version	Bearer 哈希会话、轮序和 version 校验；服务端结算	越权和重放必须拒绝且余额不变；令牌不进日志
互联网→反向代理	洪泛建房/密码猜测/伪造转发头	当前未见应用限流；x-forwarded-host 进入允许列表	代理清理客户端转发头；固定 Host/Origin；限流阈值先审批再压测
房间服务→磁盘	磁盘满/权限错/异常终止	写.tmp 后 rename；内存先更新	确认失败后内存与磁盘分歧；停止写入、备份两者、重启恢复验证
静态根目录→公网	非预期源码/审计文档被公开	serve 以仓库为静态根，拒绝点目录和越界 symlink	上线使用受控发布根；列允许资源，禁止含会话/个人信息文件
浏览器存储→本机用户	令牌/存档读取与篡改	离线无跨设备权限保证；在线权威在服务	共享设备退出清会话；不把离线存档当可信服务器状态

2 一致性、恢复与接口约定

写磁盘队列只串行化落盘，不承诺通用数据库事务或通用幂等。action 在克隆规则状态成功后替换，但 persist 抛错仍可能已修改内存。收到失败或超时先 GET 状态并核对 version、pending 与金额；不能把超时等同于未执行。GET 可更新 presence，故不得仅凭 version 变化认定交易成功。任何补偿必须依据业务状态并经授权。

情况	服务/客户端动作	应保存证据
409 并发/旧版本	拉取最新状态，核对当前决策；用户确认后重新发起仍有效动作	前后 version、action、无敏感 token 的请求 ID、金额快照
超时/5xx/写盘失败	冻结自动重放，GET 核对；运维检查写盘，必要停写	错误码、内存/磁盘副本 hash、恢复过程
坏存档启动	服务 load 报错不监听；保留损坏原件，从已校验备份恢复	原件 hash、备份 hash、启动日志和房间回放
滚动/多副本	当前禁止多个进程共享 JSON 存储；升级先停写	进程数、配置与唯一写入者证明
契约状态码	OpenAPI 已收敛端点错误码；400 注明异常统一映射，其他码按实际路径声明	逐路径实际触发日志；未验证标待执行

3 恢复作业卡（隔离演练）

步骤	操作	退出条件/证据
1 选环境	仅在隔离测试目录设置 CASHFLOW_ROOMS_FILE；记录版本、OS、Node、浏览器	禁止对用户当前存档直接故障注入
2 建基线	建房/加入/开局/合法动作，保存 room 及存档 sha256	脱敏 room 快照、余额/资产/version
3 停写备份	停止入口流量；结束服务；复制存档、配置、版本包到只读备份	备份路径、hash、权限、时间
4 故障注入	分别测试无写权限、损坏 JSON、旧版本样例；每次使用独立副本	预期失败不得默默覆盖原档；不要报告已测
5 恢复	还原同版本兼容备份；单进程启动；GET 健康及认证房间	healthz 只证明进程活；需真实读写才证明可用
6 验证解除	双客户端检查轮序、pending、资产、现金；一次动作后重启再核对	QA 与技术签署；恢复耗时实测后再设 RTO/RPO

4 环境与分级准入

级别	要求	当前结论
文档评审交付	结构可读、证据可追溯、待办不伪关闭	本轮修订可交付评审
阶段试玩	受测构建 hash 一致、核心回归通过、已知差异明示	已有历史阶段包；非本轮重发游戏

级别	要求	当前结论
公开在线服务	安全、负载、恢复、隐私与资源权利评审；实际域名测试	未取得生产签署
原版全等	全部原版内容与 49 运行界面证据、规则差异决策、真实入口与 UAT	门禁阻断

工具链应随每次执行记录：git 提交、ZIP SHA、Node 精确版本、npm/Playwright 版本、Chromium 版本、OS、CPU/内存、视口/DPR/缩放、网络与代理配置。支持矩阵和 NFR 必须先批准；本说明不擅自制定 SLA。

5 GX-07 交易数量上限交叉审查

engine.js:70 通用 buy 允许 1 至 1,000,000 份；stockQuantity/confirmStock 在 184/188 行对证券交易买入采用 99,999 上限，卖出上限为持仓。两条入口的业务边界不同，不能只在 UI 设 max 后宣称服务端统一。技术风险是绕过某界面调用另一合法 action 可出现不同容量语义，而非已证明越权。应由玩法负责人决定分支设计是否有意保留；确定后统一或显式区分契约，并增加 99,999/100,000/1,000,000/1,000,001 四个边界的直接引擎与在线 action 测试。当前只修订规格，未改变代码或判定原版上限。